

The General Data Protection Regulation (Regulation (EU) 2016/679), abbreviated GDPR, is a European Union regulation on information privacy in the European Union (EU) and the European Economic Area (EEA). The GDPR is an important component of EU privacy law and human rights law, in particular Article 8(1) of the Charter of Fundamental Rights of the European Union. It also governs the transfer of personal data outside the EU and EEA. The GDPR's goals are to enhance individuals' control and rights over their personal information and to simplify the regulations for international business. It supersedes the Data Protection Directive 95/46/EC and, among other things, simplifies the terminology.

The European Parliament and Council of the European Union adopted the GDPR on 14 April 2016, to become effective on 25 May 2018. As an EU regulation (instead of a directive), the GDPR has direct legal effect and does not require transposition into national law. However, it also provides flexibility for individual member states to modify (derogate from) some of its provisions.

As an example of the Brussels effect, the regulation became a model for many other laws around the world, including in Brazil, Japan, Singapore, South Africa, South Korea, Sri Lanka, and Thailand. After leaving the European Union, the United Kingdom enacted its "UK GDPR", identical to the GDPR. The California Consumer Privacy Act (CCPA), adopted on 28 June 2018, has many similarities with the GDPR.

Contents

The GDPR 2016 has eleven chapters, concerning general provisions, principles, rights of the data subject, duties of data controllers or processors, transfers of personal data to third-party countries, supervisory authorities, cooperation among member states, remedies, liability or penalties for breach of rights, provisions related to specific processing situations, and miscellaneous final provisions. The GDPR also contains 173 recitals purposed to clarify scope and rationale for the regulatory provisions, as well as its legislative intents – Recital 4, for

instance, begins by saying that the processing of personal data should be "designed to serve mankind".

General provisions

The regulation applies if the data controller, or processor, or the data subject (person) is based in the EU. The regulation also applies to organisations based outside the EU if they collect or process personal data of individuals located inside the EU. The regulation does not apply to the processing of data by private persons provided that the purpose has no connection to a professional or commercial activity." (Recital 18).

According to the European Commission, "Personal data is information that relates to an identified or identifiable individual. If you cannot directly identify an individual from that information, then you need to consider whether the individual is still identifiable. You should take into account the information you are processing together with all the means reasonably likely to be used by either you or any other person to identify that individual." The precise definitions of terms such as "personal data", "processing", "data subject", "controller", and "processor" are stated in Article 4.

The regulation does not purport to apply to the processing of personal data for national security activities or law enforcement of the EU; however, industry groups concerned about facing a potential conflict of laws have questioned whether Article 48 could be invoked to seek to prevent a data controller subject to a third country's laws from complying with a legal order from that country's law enforcement, judicial, or national security authorities to disclose to such authorities the personal data of an EU person, regardless of whether the data resides in or out of the EU. Article 48 states that any judgement of a court or tribunal and any decision of an administrative authority of a third country requiring a controller or processor to transfer or disclose personal data may not be recognised or enforceable in any manner unless based on an international agreement, like a mutual legal assistance treaty in force between the

requesting third (non-EU) country and the EU or a member state. The data protection reform package also includes a separate Data Protection Directive for the police and criminal justice sector that provides rules on personal data exchanges at State level, Union level, and international levels.

A single set of rules applies to all EU member states. Each member state establishes an independent supervisory authority (SA) to hear and investigate complaints, sanction administrative offences, etc. SAs in each member state co-operate with other SAs, providing mutual assistance and organising joint operations. If a business has multiple establishments in the EU, it must have a single SA as its "lead authority", based on the location of its "main establishment" where the main processing activities take place. The lead authority thus acts as a "one-stop shop" to supervise all the processing activities of that business throughout the EU. A European Data Protection Board (EDPB) co-ordinates the SAs. EDPB thus replaces the Article 29 Data Protection Working Party. There are exceptions for data processed in an employment context or in national security that still might be subject to individual country regulations.

Principles and lawful purposes

Article 5 sets out six principles relating to the lawfulness of processing personal data. The first of these specifies that data must be processed lawfully, fairly and in a transparent manner. Article 6 develops this principle by specifying that personal data may not be processed unless there is at least one legal basis for doing so. The other principles refer to "purpose limitation", "data minimisation", "accuracy", "storage limitation", and "integrity and confidentiality".

Article 6 states that the lawful purposes are:

- (a) If the data subject has given consent to the processing of his or her personal data;
- (b) To fulfill contractual obligations with a data subject, or for tasks at the request of a data subject who is in the process of entering into a contract;

- (c) To comply with a data controller's legal obligations;
- (d) To protect the vital interests of a data subject or another individual;
- (e) To perform a task in the public interest or in official authority;
- (f) For the legitimate interests of a data controller or a third party, unless these interests are overridden by interests of the data subject or her or his rights according to the Charter of Fundamental Rights (especially in the case of children).

If informed consent is used as the lawful basis for processing, consent must have been explicit for data collected and each purpose data is used for. Consent must be a specific, freely given, plainly worded, and unambiguous affirmation given by the data subject; an online form which has consent options structured as an opt-out selected by default is a violation of the GDPR, as the consent is not unambiguously affirmed by the user. In addition, multiple types of processing may not be "bundled" together into a single affirmation prompt, as this is not specific to each use of data, and the individual permissions are not freely given. (Recital 32).

Data subjects must be allowed to withdraw this consent at any time, and the process of doing so must not be harder than it was to opt in. A data controller may not refuse service to users who decline consent to processing that is not strictly necessary in order to use the service. Consent for children, defined in the regulation as being less than 16 years old (although with the option for member states to individually make it as low as 13 years old), must be given by the child's parent or custodian, and verifiable.

If consent to processing was already provided under the Data Protection Directive, a data controller does not have to re-obtain consent if the processing is documented and obtained in compliance with the GDPR's requirements (Recital 171).

Rights of the data subject

Transparency and modalities

Article 12 requires the data controller to provide information to the "data subject in a concise,

transparent, intelligible and easily accessible form, using clear and plain language, in particular for any information addressed specifically to a child."

Information and access

The right of access (Article 15) is a data subject right. It gives people the right to access their personal data and information about how this personal data is being processed. A data controller must provide, upon request, an overview of the categories of data that are being processed as well as a copy of the actual data; furthermore, the data controller has to inform the data subject on details about the processing, such as the purposes of the processing, with whom the data is shared, and how it acquired the data.

A data subject must be able to transfer personal data from one electronic processing system to and into another, without being prevented from doing so by the data controller. Data that has been sufficiently anonymised is excluded, but data that has been only de-identified but remains possible to link to the individual in question, such as by providing the relevant identifier, is not. In practice, however, providing such identifiers can be challenging, such as in the case of Apple's Siri, where voice and transcript data is stored with a personal identifier that the manufacturer restricts access to, or in online behavioural targeting, which relies heavily on device fingerprints that can be challenging to capture, send, and verify.

Both data being 'provided' by the data subject and data being 'observed', such as about behaviour, are included. In addition, the data must be provided by the controller in a structured and commonly used standard electronic format. The right to data portability is provided by Article 20.

Rectification and erasure

A right to be forgotten was replaced by a more limited right of erasure in the version of the GDPR that was adopted by the European Parliament in March 2014. Article 17 provides that

the data subject has the right to request erasure of personal data related to them on any one of a number of grounds, including noncompliance with Article 6(1) (lawfulness) that includes a case (f) if the legitimate interests of the controller are overridden by the interests or fundamental rights and freedoms of the data subject, which require protection of personal data (see also Google Spain SL, Google Inc. v Agencia Española de Protección de Datos, Mario Costeja González).

Right to object and automated decisions

Article 21 of the GDPR allows an individual to object to processing personal information for marketing or non-service related purposes. This means the data controller must allow an individual the right to stop or prevent controller from processing their personal data.

There are some instances where this objection does not apply. For example, if:

Legal or official authority is being carried out

"Legitimate interest", where the organisation needs to process data in order to provide the data subject with a service they signed up for

A task being carried out for public interest.

GDPR is also clear that the data controller must inform individuals of their right to object from the first communication the controller has with them. This should be clear and separate from any other information the controller is providing and give them their options for how best to object to the processing of their data.

There are instances the controller can refuse a request, in the circumstances that the objection request is "manifestly unfounded" or "excessive", so each case of objection must be looked at individually. Other countries such as Canada are also, following the GDPR, considering legislation to regulate automated decision making under privacy laws, even though there are policy questions as to whether this is the best way to regulate AI.

Right to compensation

Article 82 of the GDPR stipulates that any person who has suffered material or non-material damage as a result of an infringement of the GDPR has the right to receive compensation from the controller or processor for the damage suffered.

In the judgment *Österreichische Post* (C-300/21) the Court of Justice of the European Union gave an interpretation of the right to compensation. Article 82(1) GDPR requires for the award of damages (i) an infringement of the GDPR, (ii) (actual) damage suffered and (iii) a causal link between the infringement and the damage suffered. It is not necessary that the damage suffered reaches a certain degree of seriousness. There is no European defined concept of damage. Compensation is determined nationally in accordance with national law. The principles of equivalence and effectiveness must be taken into account: The "principle of equivalence" dictates that the procedure for EU cases must be equivalent to the procedure for a domestic case, and the "principle of effectiveness" requires that the procedure cannot render the law functionally ineffective.

Data processors are only liable for damage caused by processing in breach of obligations specifically imposed on processors by the GDPR, or for damage caused by processing which is outside, or contrary to, the lawful instructions of the data controller.

Controller and processor

Data controllers must clearly disclose any data collection, declare the lawful basis and purpose for data processing, and state how long data is being retained and if it is being shared with any third parties or outside of the EEA. Firms have the obligation to protect data of employees and consumers to the degree where only the necessary data is extracted with minimum interference with data privacy from employees, consumers, or third parties. Firms should have internal controls and regulations for various departments such as audit, internal controls, and

operations. Data subjects have the right to request a portable copy of the data collected by a controller in a common format, as well as the right to have their data erased under certain circumstances. Public authorities, and businesses whose core activities consist of regular or systematic processing of personal data, are required to employ a data protection officer (DPO), who is responsible for managing compliance with the GDPR. Data controllers must report data breaches to national supervisory authorities within 72 hours if they have an adverse effect on user privacy. In some cases, violators of the GDPR may be fined up to €20 million or up to 4% of the annual worldwide turnover of the preceding financial year in case of an enterprise, whichever is greater.

To be able to demonstrate compliance with the GDPR, the data controller must implement measures that meet the principles of data protection by design and by default. Article 25 requires data protection measures to be designed into the development of business processes for products and services. Such measures include pseudonymising personal data, by the controller, as soon as possible (Recital 78). It is the responsibility and the liability of the data controller to implement effective measures and be able to demonstrate the compliance of processing activities even if the processing is carried out by a data processor on behalf of the controller (Recital 74). When data is collected, data subjects must be clearly informed about the extent of data collection, the legal basis for the processing of personal data, how long data is retained, if data is being transferred to a third-party and/or outside the EU, and any automated decision-making that is made on a solely algorithmic basis. Data subjects must be informed of their privacy rights under the GDPR, including their right to revoke consent to data processing at any time, their right to view their personal data and access an overview of how it is being processed, their right to obtain a portable copy of the stored data, their right to erasure of their data under certain circumstances, their right to contest any automated decision-making that was made on a solely algorithmic basis, and their right to file complaints with a Data Protection Authority. As such, the data subject must also be provided with contact

details for the data controller and their designated data protection officer, where applicable.

Data protection impact assessments (Article 35) have to be conducted when specific risks occur to the rights and freedoms of data subjects. Risk assessment and mitigation is required and prior approval of the data protection authorities is required for high risks.

Article 25 requires data protection to be designed into the development of business processes for products and services. Privacy settings must therefore be set at a high level by default, and technical and procedural measures shall be taken by the controller to make sure that the processing, throughout the whole processing lifecycle, complies with the regulation. Controllers shall also implement mechanisms to ensure that personal data is not processed unless necessary for each specific purpose. This is known as data minimisation.

A report by the European Union Agency for Network and Information Security elaborates on what needs to be done to achieve privacy and data protection by default. It specifies that encryption and decryption operations must be carried out locally, not by remote service, because both keys and data must remain in the power of the data owner if any privacy is to be achieved. The report specifies that outsourced data storage on remote clouds is practical and relatively safe if only the data owner, not the cloud service, holds the decryption keys.

Pseudonymisation

According to the GDPR, pseudonymisation is a required process for stored data that transforms personal data in such a way that the resulting data cannot be attributed to a specific data subject without the use of additional information (as an alternative to the other option of complete data anonymisation). An example is encryption, which renders the original data unintelligible in a process that cannot be reversed without access to the correct decryption key. The GDPR requires for the additional information (such as the decryption key) to be kept separately from the pseudonymised data.

Another example of pseudonymisation is tokenisation, which is a non-mathematical approach

to protecting data at rest that replaces sensitive data with non-sensitive substitutes, referred to as tokens. While the tokens have no extrinsic or exploitable meaning or value, they allow for specific data to be fully or partially visible for processing and analytics while sensitive information is kept hidden. Tokenisation does not alter the type or length of data, which means it can be processed by legacy systems such as databases that may be sensitive to data length and type. This also requires much fewer computational resources to process and less storage space in databases than traditionally encrypted data.

Pseudonymisation is a privacy-enhancing technology and is recommended to reduce the risks to the concerned data subjects and also to help controllers and processors to meet their data protection obligations (Recital 28).

Records of processing activities

According to Article 30 records of processing activities have to be maintained by each organisation matching one of following criteria:

employing more than 250 people;

the processing it carries out is likely to result in a risk to the rights and freedoms of data subjects;

the processing is not occasional;

processing includes special categories of data as referred to in Article 9(1) or personal data relating to criminal convictions and offences referred to in Article 10.

Such requirements may be modified by each EU country. The records shall be in electronic form and the controller or the processor and, where applicable, the controller's or the processor's representative, shall make the record available to the supervisory authority on request.

Records of controller shall contain all of the following information:

the name and contact details of the controller and, where applicable, the joint controller, the controller's representative and the data protection officer;

the purposes of the processing;

a description of the categories of data subjects and of the categories of personal data;

the categories of recipients to whom the personal data have been or will be disclosed including recipients in third countries or international organisations;

where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

where possible, the envisaged time limits for erasure of the different categories of data;

where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

Records of processor shall contain all of the following information:

the name and contact details of the processor or processors and of each controller on behalf of which the processor is acting, and, where applicable, of the controller's or the processor's representative, and the data protection officer;

the categories of processing carried out on behalf of each controller;

where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

Security of personal data

Controllers and processors of personal data must put in place appropriate technical and organizational measures to implement the data protection principles. Business processes that handle personal data must be designed and built with consideration of the principles and provide safeguards to protect data (for example, using pseudonymization or full anonymization where appropriate). Data controllers must design information systems with privacy in mind. For instance, using the highest-possible privacy settings by default, so that the datasets are not publicly available by default and cannot be used to identify a subject. No personal data may be processed unless this processing is done under one of the six lawful bases specified by the regulation (consent, contract, public task, vital interest, legitimate interest or legal requirement). When the processing is based on consent the data subject has the right to revoke it at any time.

Article 33 states the data controller is under a legal obligation to notify the supervisory authority without undue delay unless the breach is unlikely to result in a risk to the rights and freedoms of the individuals. There is a maximum of 72 hours after becoming aware of the data breach to make the report. Individuals have to be notified if a high risk of an adverse impact is determined. In addition, the data processor will have to notify the controller without undue delay after becoming aware of a personal data breach. However, the notice to data subjects is not required if the data controller has implemented appropriate technical and organisational protection measures that render the personal data unintelligible to any person who is not authorised to access it, such as encryption.

Data protection officer

Article 37 requires appointment of a data protection officer. If processing is carried out by a public authority (except for courts or independent judicial authorities when acting in their

judicial capacity), or if processing operations involve regular and systematic monitoring of data subjects on a large scale, or if processing on a large scale of special categories of data and personal data relating to criminal convictions and offences (Articles 9 and Article 10) a data protection officer (DPO)—a person with expert knowledge of data protection law and practices—must be designated to assist the controller or processor in monitoring their internal compliance with the Regulation.

A designated DPO can be a current member of staff of a controller or processor, or the role can be outsourced to an external person or agency through a service contract. In any case, the processing body must make sure that there is no conflict of interest in other roles or interests that a DPO may hold. The contact details for the DPO must be published by the processing organisation (for example, in a privacy notice) and registered with the supervisory authority.

The DPO is similar to a compliance officer and is also expected to be proficient at managing IT processes, data security (including dealing with cyberattacks) and other critical business continuity issues associated with the holding and processing of personal and sensitive data. The skill set required stretches beyond understanding legal compliance with data protection laws and regulations. The DPO must maintain a living data inventory of all data collected and stored on behalf of the organization. More details on the function and the role of data protection officer were given on 13 December 2016 (revised 5 April 2017) in a guideline document.

Organisations based outside the EU must also appoint an EU-based person as a representative and point of contact for their GDPR obligations. This is a distinct role from a DPO, although there is overlap in responsibilities that suggest that this role can also be held by the designated DPO.

GDPR Certification

Article 42 and 43 of the GDPR set the legal basis for formal GDPR certifications. They set the

basis for two categories of certifications:

National certification schemes, whose application is limited to a single EU/EEA country;

European Data Protection Seals, which are recognized by all EU and EEA jurisdictions.

According to Art. 42 GDPR, the purpose of this certification is to demonstrate “compliance with the GDPR of processing operations by controllers and processors”. There are over 70 references to certification in the GDPR, encompassing various obligations such as:

Adequacy of the technical and organizational measures;

Data sharing with data processors;

Data protection by design and by default;

International data transfers.

The GDPR certification also contributes to reduce the legal and financial risks of applicants, as well as of data controllers using certified data processing services.

The adoption of the European Data Protection Seals is under the responsibility of the European Data Protection Board (EDPB) and is recognized across all EU and EEA Member States.

In October 2022, the Europrivacy certification criteria were officially recognized by the European Data Protection Board (EDPB) to serve as European Data Protection Seal. Europrivacy was developed by the European research programme and is managed by the European Centre for Certification and Privacy (ECCP) in Luxembourg.

Remedies, liability and penalties

Besides the definitions as a criminal offence according to national law following Article 83 GDPR the following sanctions can be imposed:

a warning in writing in cases of first and non-intentional noncompliance

regular periodic data protection audits

a fine up to €10 million or up to 2% of the annual worldwide turnover of the preceding financial year in case of an enterprise, whichever is greater, if there has been an infringement of the following provisions (Article 83, Paragraph 4):

the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39, and 42 and 43

the obligations of the certification body pursuant to Articles 42 and 43

the obligations of the monitoring body pursuant to Article 41(4)

a fine up to €20 million or up to 4% of the annual worldwide turnover of the preceding financial year in case of an enterprise, whichever is greater, if there has been an infringement of the following provisions (Article 83, Paragraph 5 & 6):

the basic principles for processing, including conditions for consent, pursuant to Articles 5, 6, 7, and 9

the data subjects' rights pursuant to Articles 12 to 22

the transfers of personal data to a recipient in a third country or an international organisation pursuant to Articles 44 to 49

any obligations pursuant to member state law adopted under Chapter IX

noncompliance with an order or a temporary or definitive limitation on processing or the suspension of data flows by the supervisory authority pursuant to Article 58(2) or failure to provide access in violation of Article 58(1)

Exemptions

These are some cases which are not addressed in the GDPR specifically, thus are treated as exemptions.

Personal or household activities

Law enforcement

National security

Conversely, an entity or more precisely an "enterprise" has to be engaged in "economic activity" to be covered by the GDPR. Economic activity is defined broadly under European Union competition law.

Applicability outside of the European Union

The GDPR also applies to data controllers and processors outside of the European Economic Area (EEA) if they are engaged in the "offering of goods or services" (regardless of whether a payment is required) to data subjects within the EEA, or are monitoring the behaviour of data subjects within the EEA (Article 3(2)). The regulation applies regardless of where the processing takes place. This has been interpreted as intentionally giving GDPR extraterritorial jurisdiction for non-EU establishments if they are doing business with people located in the EU. It is questionable whether the EU or its member states will in practice be able to enforce GDPR against organisations which have no establishment in the EU.

EU Representative

Under Article 27, non-EU establishments subject to GDPR are obliged to have a designee within the European Union, an "EU Representative", to serve as a point of contact for their obligations under the regulation. The EU Representative is the Controller's or Processor's contact person vis-à-vis European privacy supervisors and data subjects, in all matters relating to processing, to ensure compliance with this GDPR. A natural (individual) or legal (corporation) person can play the role of an EU Representative. The non-EU establishment must issue a duly signed document (letter of accreditation) designating a given individual or company as its EU Representative. The said designation can only be given in writing.

An establishment's failure to designate an EU Representative is considered ignorance of the regulation and relevant obligations, which itself is a violation of the GDPR subject to fines of up to €10 million or up to 2% of the annual worldwide turnover of the preceding financial year in case of an enterprise, whichever is greater. The intentional or negligent (willful blindness) character of the infringement (failure to designate an EU Representative) may rather constitute aggravating factors.

An establishment does not need to name an EU Representative if they only engage in occasional processing that does not include, on a large scale, processing of special categories of data as referred to in Article 9(1) of GDPR or processing of personal data relating to criminal convictions and offences referred to in Article 10, and such processing is unlikely to result in a risk to the rights and freedoms of natural persons, taking into account the nature, context, scope and purposes of the processing. Non-EU public authorities and bodies are equally exempted.

Third countries

Chapter V of the GDPR forbids the transfer of the personal data of EU data subjects to countries outside of the EEA — known as third countries — unless appropriate safeguards are imposed, or the third country's data protection regulations are formally considered adequate by the European Commission (Article 45). Binding corporate rules, standard contractual clauses for data protection issued by a Data Processing Agreement (DPA), or a scheme of binding and enforceable commitments by the data controller or processor situated in a third country, are among examples.

United Kingdom implementation

The applicability of GDPR in the United Kingdom is affected by Brexit. Although the United Kingdom formally withdrew from the European Union on 31 January 2020, it remained subject

to EU law, including GDPR, until the end of the transition period on 31 December 2020. The United Kingdom granted royal assent to the Data Protection Act 2018 on 23 May 2018, which augmented the GDPR, including aspects of the regulation that are to be determined by national law, and criminal offences for knowingly or recklessly obtaining, redistributing, or retaining personal data without the consent of the data controller.

Under the European Union (Withdrawal) Act 2018, existing and relevant EU law was transposed into UK law upon completion of the transition, and the GDPR was amended by statutory instrument to remove certain provisions no longer needed due to the UK's non-membership in the EU. Thereafter, the regulation is referred to as "UK GDPR". The UK does not restrict the transfer of personal data to countries within the EEA under UK GDPR. However, the UK is a third country under the EU GDPR, meaning that personal data may not be transferred from EU member states to the UK unless appropriate safeguards are imposed, or the European Commission performs an adequacy decision on the suitability of British data protection legislation (Chapter V). As part of the withdrawal agreement, the European Commission committed to perform an adequacy assessment. On 28 June 2021, the Commission confirmed the adequacy of the UK GDPR for four years; This was set to expire on 27 June 2025, but was extended for six months to give the Commission time to assess the impact of the Data (Use and Access) Act 2025. On 19 December 2025 the Commission renewed the 2021 adequacy decision until 27 December 2031.

In April 2019, the UK Information Commissioner's Office (ICO) issued a children's code of practice for social networking services when used by minors, enforceable under GDPR, which also includes restrictions on "like" and "streak" mechanisms in order to discourage social media addiction and on the use of this data for processing interests.

In March 2021, Secretary of State for Digital, Culture, Media and Sport Oliver Dowden stated that the UK was exploring divergence from the EU GDPR in order to "[focus] more on the outcomes that we want to have and less on the burdens of the rules imposed on individual

businesses".

Misconceptions

Some common misconceptions about GDPR include:

All processing of personal data requires consent of the data subject

In fact, data can be processed without consent if one of the other five lawful bases for processing applies, and obtaining consent may often be inappropriate.

Individuals have an absolute right to have their data deleted (right to be forgotten)

Whilst there is an absolute right to opt out of direct marketing, data controllers can continue to process personal data where they have a lawful basis to do so, as long as the data remain necessary for the purpose for which it was originally collected.

Removing individuals' names from records takes them out of scope of GDPR

"Pseudonymous" data where an individual is identified by a number can still be personal data if the data controller is capable of tying that data back to an individual in another way.

GDPR applies to anyone processing personal data of EU citizens anywhere in the world

In fact, it applies to non-EU established organizations only where they are processing data of data subjects located in the EU (irrespective of their citizenship) and then only when supplying goods or services to them, or monitoring their behaviour.

Reception

As per a study conducted by Deloitte in 2018, 92% of companies believe they are able to comply with GDPR in their business practices in the long run.

Companies operating outside of the EU have invested heavily to align their business practices with GDPR. The area of GDPR consent has a number of implications for businesses who record calls as a matter of practice. A typical disclaimer is not considered sufficient to gain assumed

consent to record calls. Additionally, when recording has commenced, should the caller withdraw their consent, then the agent receiving the call must be able to stop a previously started recording and ensure the recording does not get stored.

IT professionals expect that compliance with the GDPR will require additional investment overall: over 80 percent of those surveyed expected GDPR-related spending to be at least US\$100,000. The concerns were echoed in a report commissioned by the law firm Baker & McKenzie that found that "around 70 percent of respondents believe that organizations will need to invest additional budget/effort to comply with the consent, data mapping and cross-border data transfer requirements under the GDPR." The total cost for EU companies is estimated at €200 billion while for US companies the estimate is for \$41.7 billion. It has been argued that smaller businesses and startup companies might not have the financial resources to adequately comply with the GDPR, unlike the larger international technology firms (such as Facebook and Google) that the regulation is ostensibly meant to target first and foremost. A lack of knowledge and understanding of the regulations has also been a concern in the lead-up to its adoption. A counter-argument to this has been that companies were made aware of these changes two years prior to them coming into effect and should have had enough time to prepare.

The regulations, including whether an enterprise must have a data protection officer, have been criticized for potential administrative burden and unclear compliance requirements. Although data minimisation is a requirement, with pseudonymisation being one of the possible means, the regulation provides no guidance on how or what constitutes an effective data de-identification scheme, with a grey area on what would be considered as inadequate pseudonymisation subject to Section 5 enforcement actions. There is also concern regarding the implementation of the GDPR in blockchain systems, as the transparent and fixed record of blockchain transactions contradicts the very nature of the GDPR. Many media outlets have commented on the introduction of a "right to explanation" of algorithmic decisions, but legal

scholars have since argued that the existence of such a right is highly unclear without judicial tests and is limited at best.

The GDPR has garnered support from businesses who regard it as an opportunity to improve their data management. Mark Zuckerberg has also called it a "very positive step for the Internet", and has called for GDPR-style laws to be adopted in the US. Consumer rights groups such as The European Consumer Organisation are among the most vocal proponents of the legislation. Other supporters have attributed its passage to the whistleblower Edward Snowden. Free software advocate Richard Stallman has praised some aspects of the GDPR but called for additional safeguards to prevent technology companies from "manufacturing consent".

Impact

Academic experts who participated in the formulation of the GDPR wrote that the law "is the most consequential regulatory development in information policy in a generation. The GDPR brings personal data into a complex and protective regulatory regime."

Despite having had at least two years to prepare and do so, many companies and websites changed their privacy policies and features worldwide directly prior to GDPR's implementation, and customarily provided email and other notifications discussing these changes. This was criticised for resulting in a fatiguing number of communications, while experts noted that some reminder emails incorrectly asserted that new consent for data processing had to be obtained for when the GDPR took effect (any previously obtained consent to processing is valid as long as it met the regulation's requirements). Phishing scams also emerged using falsified versions of GDPR-related emails, and it was also argued that some GDPR notice emails may have actually been sent in violation of anti-spam laws. In March 2019, a provider of compliance software found that many websites operated by EU member state governments contained embedded tracking from ad technology providers.

The deluge of GDPR-related notices also inspired memes, including those surrounding privacy policy notices being delivered by atypical means (such as a Ouija board or Star Wars opening crawl), suggesting that Santa Claus's "naughty or nice" list was a violation, and a recording of excerpts from the regulation by a former BBC Radio 4 Shipping Forecast announcer. A blog, GDPR Hall of Shame, was also created to showcase unusual delivery of GDPR notices, and attempts at compliance that contained egregious violations of the regulation's requirements. Its author remarked that the regulation "has a lot of nitty gritty, in-the-weeds details, but not a lot of information about how to comply", but also acknowledged that businesses had two years to comply, making some of its responses unjustified.

Research indicates that approximately 25% of software vulnerabilities have GDPR implications. Since Article 33 emphasizes breaches, not bugs, security experts advise companies to invest in processes and capabilities to identify vulnerabilities before they can be exploited, including coordinated vulnerability disclosure processes. An investigation of Android apps' privacy policies, data access capabilities, and data access behaviour has shown that numerous apps display a somewhat privacy-friendlier behaviour since the GDPR was implemented, although they still retain most of their data access privileges in their code. An investigation of the Norwegian Consumer Council into the post-GDPR data subject dashboards on social media platforms (such as Google dashboard) has concluded that large social media firms deploy deceptive tactics in order to discourage their customers from sharpening their privacy settings.

On the effective date, some websites began to block visitors from EU countries entirely (including Instapaper, Unroll.me, Tubi and Tribune Publishing-owned newspapers, such as the Chicago Tribune and the Los Angeles Times) or redirect them to stripped-down versions of their services (in the case of NPR and USA Today) with limited functionality and/or no advertising so that they will not be liable. Some companies, such as Klout, and several online video games, ceased operations entirely to coincide with its implementation, citing the GDPR

as a burden on their continued operations, especially due to the business model of the former. The volume of online behavioural advertising placements in Europe fell 25–40% on 25 May 2018.

In 2020, two years after the GDPR began its implementation, the European Commission assessed that users across the EU had increased their knowledge about their rights, stating that "69% of the population above the age of 16 in the EU have heard about the GDPR and 71% of people heard about their national data protection authority." The commission also found that privacy has become a competitive quality for companies which consumers are taking into account in their decisionmaking processes.

Enforcement and inconsistency

Facebook and subsidiaries WhatsApp and Instagram, as well as Google LLC (targeting Android), were immediately sued by Max Schrems's non-profit NOYB just hours after midnight on 25 May 2018, for their use of "forced consent". Schrems asserts that both companies violated Article 7(4) by not presenting opt-ins for data processing consent on an individualized basis, and requiring users to consent to all data processing activities (including those not strictly necessary) or would be forbidden from using the services. On 21 January 2019, Google was fined €50 million by the French DPA for showing insufficient control, consent, and transparency over use of personal data for behavioural advertising. In November 2018, following a journalistic investigation into Liviu Dragnea, the Romanian DPA (ANSPDCP) used a GDPR request to demand information on the RISE Project's sources.

In July 2019, the British Information Commissioner's Office issued an intention to fine British Airways a record £183 million (1.5% of turnover) for poor security arrangements that enabled a 2018 web skimming attack affecting around 380,000 transactions. British Airways was ultimately fined a reduced amount of £20m, with the ICO noting that they had "considered both representations from BA and the economic impact of COVID-19 on their business before

setting a final penalty".

In December 2019, Politico reported that Ireland and Luxembourg – two smaller EU countries that have had a reputation as a tax havens and (especially in the case of Ireland) as a base for European subsidiaries of U.S. big tech companies – were facing significant backlogs in their investigations of major foreign companies under GDPR, with Ireland citing the complexity of the regulation as a factor. Critics interviewed by Politico also argued that enforcement was also being hampered by varying interpretations between member states, the prioritisation of guidance over enforcement by some authorities, and a lack of cooperation between member states.

In November 2021, Irish Council for Civil Liberties lodged a formal complaint of the Commission that it is in breach of its obligation under EU Law to carefully monitor how Ireland applies the GDPR. Until January 2023, the Commission published a new commitment based on the complaint of ICCL. While companies are now subject to legal obligations, there are still various inconsistencies in the practical and technical implementation of GDPR. As an example, according to the GDPR's right to access, the companies are obliged to provide data subjects with the data they gather about them. However, in a study on loyalty cards in Germany, companies did not provide the data subjects with the exact information of the purchased articles. One might argue that such companies do not collect the information of the purchased articles, which does not conform with their business models. Therefore, data subjects tend to see that as a GDPR violation. As a result, studies have suggested for a better control through authorities. According to the GDPR, end-users' consent should be valid, freely given, specific, informed and active. However, the lack of enforceability regarding obtaining lawful consents has been a challenge. As an example, a 2020 study, showed that the Big Tech, i.e. Google, Amazon, Facebook, Apple, and Microsoft (GAFAM), use dark patterns in their consent obtaining mechanisms, which raises doubts regarding the lawfulness of the acquired consent. In March 2021, EU member states led by France were reported to be attempting to modify the

impact of the privacy regulation in Europe by exempting national security agencies. After around 160 million Euros in GDPR fines were imposed in 2020, the figure was already over one billion Euros in 2021.

In 2024 and early 2025, GDPR enforcement actions intensified. The Irish Data Protection Commission (DPC) imposed a €345 million fine on TikTok for violations related to children's data privacy and insufficient safeguards for young users. In January 2025, Meta was fined €1.2 billion for unlawful data transfers between the EU and the US, marking one of the largest GDPR fines to date. On 12 February 2025, the European Commission abandoned proposed regulations on technology patents, AI liability, and privacy for messaging apps due to strong lobbying and a lack of consensus among EU lawmakers, with major tech firms opposing the changes.

Influence on foreign laws

Mass adoption of these new privacy standards by multinational companies has been cited as an example of the "Brussels effect", a phenomenon wherein European laws and regulations are used as a baseline due to their gravitas.

The U.S. state of California passed the California Consumer Privacy Act on 28 June 2018, taking effect on 1 January 2020; it grants rights to transparency and control over the collection of personal information by companies in a similar means to GDPR. Critics have argued that such laws need to be implemented at the federal level to be effective, as a collection of state-level laws would have varying standards that would complicate compliance. Two other U.S. states have since enacted similar legislation: Virginia passed the Consumer Data Privacy Act on 2 March 2021, and Colorado enacted the Colorado Privacy Act on 8 July 2021.

The Republic of Turkey, a candidate for European Union membership, adopted the Law on The Protection of Personal Data on 24 March 2016 in compliance with the EU acquis. China's 2021 Personal Information Protection Law is the country's first comprehensive law on personal data

rights and is modelled after the GDPR. Switzerland will also adopt a new data protection law that largely follows EU's GDPR. With the addition of overseas regions of the European Union joining non-governmental organisational (NGO) bodies in the Caribbean region such as the Caribbean Community and Organisation of Eastern Caribbean States, the GDPR rules have become necessary to consider in the lack of any current legislation found in the region concerning privacy rights and maintaining compliance of the laws of those outer regions. The CLOUD Act, enacted in 2018, is seen by the European Data Protection Supervisor as a law in possible conflict with the GDPR.

Website views and revenue

A 2024 study found that GDPR reduced both EU user website page views and website revenue by 12%.

Timeline

25 January 2012: The proposal for the GDPR was released.

21 October 2013: The European Parliament Committee on Civil Liberties, Justice and Home Affairs (LIBE) had its orientation vote.

15 December 2015: Negotiations between the European Parliament, Council and Commission (Formal Trilogue meeting) resulted in a joint proposal.

17 December 2015: The European Parliament's LIBE Committee voted for the negotiations between the three parties.

8 April 2016: Adoption by the Council of the European Union. The only member state voting against was Austria, which argued that the level of data protection in some respects falls short compared to the 1995 directive.

14 April 2016: Adoption by the European Parliament.

24 May 2016: The regulation entered into force, 20 days after its publication in the Official

Journal of the European Union.

6 May 2018: Data Protection Directive for the police and justice sectors into national legislation applicable from this day.

25 May 2018: Its provisions became directly applicable in all member states, two years after the regulations enter into force.

20 July 2018: the GDPR became valid in the EEA countries (Iceland, Liechtenstein, and Norway), after the EEA Joint Committee and the three countries agreed to follow the regulation.

EU Digital Single Market

The EU Digital Single Market strategy relates to "digital economy" activities related to businesses and people in the EU. As part of the strategy, the GDPR and the NIS Directive all apply from 25 May 2018. The proposed ePrivacy Regulation was also planned to be applicable from 25 May 2018, but will be delayed for several months. The eIDAS Regulation is also part of the strategy.

In an initial assessment, the European Council has stated that the GDPR should be considered "a prerequisite for the development of future digital policy initiatives".

See also

Similar privacy laws in other countries:

General Personal Data Protection Law (LGPD) (Brazil)

California Consumer Privacy Act (CCPA)

Children's Online Privacy Protection Act (COPPA) (USA)

Personal Information Protection Law (PIPL) (China)

Personal Data Protection Act 2012 (PDPA) (Singapore)

Protection of Personal Information Act (PoPIA) (South Africa)

Personal Data Protection Act, No. 9 of 2022 (PDPA) (Sri Lanka)

Related EU regulation:

Chat Control

Cyber Security and Resilience Bill – UK proposed legislation 2024.

Data Act, proposed EU law from 2022

Data Governance Act, proposed EU law from 2020

Digital Markets Act

Digital Services Act

EU-US Privacy Shield

European Data Protection Board (EDPB)

European Health Data Space

Privacy and Electronic Communications Directive 2002 (ePrivacy Directive, ePD)

Right to be forgotten law

Transparency and targeting of political advertising

Related concepts:

Budapest Convention on Cybercrime

Data portability

Do Not Track legislation

ePrivacy Regulation

Privacy Impact Assessment

Compliance tactics by certain companies:

Consent or pay

Notes

References

External links

[General Data Protection Regulation consolidated text](#)

[General Data Protection Regulation initial legal act](#)

[Data protection, European Commission](#)

[Procedure 2012/0011/COD Procedure for the proposed revised legal framework \(General Data Protection Regulation\)](#)

[Handbook on European data protection law, European Union Agency for Fundamental Rights](#)

[Europrivacy Official Website](#)

[ECCP – European Centre for Certification and Privacy](#)

[GDPR Certification](#)